

CEHv13 A.I MODULE 13- Hacking Web Servers

Notes by VIVEK GOSWAMI

Web Server

Web Servers are the programs that are used for hosting services.

Web Servers are deployed on separate web server hardware or installed on a host as a program.

It delivers content over Hyper Text Transfer Protocol (HTTP).

Web Servers support different types of application extensions, whereas all of them support Hypertext Markup Language (HTML).

Web server vulnerabilities:

- Improper permission of file directories
- Default configurations
- Enabling unnecessary services
- Lack of security
- Bugs
- Misconfigured SSL certificate - Drown Attack
- Enabled debugging

Open Source Web Servers

- Apache HTTP Server
- Nginx
- Apache Tomcat

Web Server Attacks

DoS/DDoS

DNS Server Hijacking

Directory Traversal Attacks

Attacker using trials and error method to access restricted directories to reveal sensitive information.

Man-in-the-Middle / Sniffing Attacks

Phishing Attacks

Website Defacement

After a successful intrusion, attacker alters and modify the content of the website.

Webserver Misconfiguration

Attacker looks for misconfigurations and vulnerabilities to exploit.

Web Cache Poisoning Attack

The attacker wipe the actual cache of the webserver and sending crafted request to store fake entries.

Web Application Attacks

- Cookie Tampering
- DoS
- SQL Injection
- Session Hijacking
- Cross-Site Request Forgery (CSRF)
- Cross-Site Scripting (XSS)
- Buffer Overflow

Attack Methodology

Information Gathering

Collecting information from internet.

robots.txt

Attacker extract information about internal files.

Web Server Footprinting

Results: the server name, type, OS, applications, etc.

Mirroring a website

Download the website to inspect offline, without any interaction to the target.

Tool:

- httrack
- Wget - wget --mirror

Vulnerability Scanning

An automated tool to inspect a website and detect vulnerabilities.

These tools perform a deep inspection of scripts, open ports, banners, etc.

Tools:

1. owasp-zap
2. openvas
3. Nessus
4. Qualys
5. Crash Test
6. burpsuite Pro
7. Nikto
8. Acunetix
9. Netsparker
10. QualysGuard

Hacking Web Passwords

- Extract passwords to gain authorised access to the system.

- A password may be obtained from social engineering, tampering with the communication, etc.

Countermeasures

- Place web server in a secure zone (behind firewall, IDS, IPS, DMZ)
- Detect potential changes (hashing, script to detect change)
- Disable insecure and unnecessary ports
- Using port 443 (HTTPS) over port 80 (HTTP)
- Encrypted traffic
- Software update
- Disable default account

Patch Management

Patch Management is an automated process to detect missing security patches, find out solutions, download patch, test the patch in an isolated environment then deploy the patch onto the systems.

Perform a Web Server Hacking using AI

AI-powered tools and techniques provide ethical hackers with enhanced capabilities to discover vulnerabilities, automate attacks, and strengthen defenses.

1. Perform Web Server Footprinting and Attacks using ShellGPT

Directory traversal

```
sgpt --shell "Perform a directory traversal on target url  
https://certifiedhacker.com using gobuster"
```

FTP Brute force

```
sgpt --shell "Attempt FTP login on target IP 10.10.1.11 with hydra using  
usernames and passwords file from /home/attacker/Wordlists"
```

Webserver Footprinting

```
sgpt --shell "Perform webserver footprinting on target IP 10.10.1.22"
```

```
sgpt --shell "Perform webserver footprinting on target IP 10.10.1.22  
with netcat"
```

Mirror a Website

```
sgpt --shell "Mirror the target website certifiedhacker.com"
```